

VULNERABILITY ASSESSMENT

Brief Analysis of Identified Vulnerabilities

1. vsftpd Compromised Source Packages Backdoor (CVE-2011-2523)

What it is: The FTP server (vsftpd version 2.3.4) contains a malicious backdoor that was covertly inserted into the official software download archive by unknown actors prior to distribution.

Why it matters: Exploitation requires zero technical sophistication. An attacker simply appends a smiley face :) to a username during the FTP login process. This triggers the backdoor, which secretly opens a listening command shell on port 6200.

Potential Impact: Total host compromise. The attacker gains immediate, unauthenticated root access to the system. For the Ghana Maritime Defense Command (GMDC), this means an adversary can silently monitor maritime communications, alter configurations, or disable the server entirely.

2. UnrealIRCd Backdoor Detection (CVE-2010-2075)

What it is: The IRC chat service is running a modified version of UnrealIRCd that includes a Trojan backdoor.

Why it matters: Similar to the FTP flaw, this allows unauthenticated remote attackers to bypass security mechanisms and send malicious payloads directly to the IRC port to execute arbitrary system commands.

Potential Impact: Because the IRC daemon executes with root privileges (uid=0), any command sent by the attacker runs with absolute administrative power. This allows full control over the GMDC server for data exfiltration or lateral movement into other restricted network segments.

3. Apache Tomcat AJP RCE "Ghostcat" (CVE-2020-1938)

What it is: A severe misconfiguration and vulnerability in the Apache JServ Protocol (AJP) connector bundled with Tomcat.

Why it matters: It allows unauthorized users to read arbitrary files from the web application's directories. If the application allows users to upload files, an attacker can upload a malicious script and force Tomcat to execute it.

Potential Impact: Remote Code Execution (RCE). An attacker could extract sensitive application source code, steal database connection strings, or take over the GMDC web portal to distribute malware to maritime personnel logging into the site.

4. Database Default Credentials (MySQL & PostgreSQL)

What it is: The core relational database systems are exposed to the network using factory-default configurations (e.g., a blank password for the MySQL root user, and postgres as the password for PostgreSQL).

Why it matters: Network security perimeters are ineffective if the databases themselves are unlocked. Automated scanners easily identified these credentials, meaning botnets or entry-level attackers could find and access them in minutes.

Potential Impact: Catastrophic data breach. Attackers can view, alter, export, or destroy all records stored in these databases. This could result in the exposure of classified naval vessel coordinates, personnel rosters, or maritime defense strategies.

5. Samba Badlock Vulnerability (CVE-2016-2118)

What it is: A vulnerability in the SMB/CIFS file-sharing protocol stemming from improper authentication level negotiation over Remote Procedure Call (RPC) channels.

Why it matters: It enables a Man-in-the-Middle (MitM) downgrade attack. If an attacker intercepts traffic between a legitimate user and the Samba server, they can strip away the

encryption and force the connection to use weaker authentication.

Potential Impact: An attacker could execute arbitrary Samba network calls in the context of the intercepted user, allowing them to view or modify sensitive GMDC security data within the Active Directory database, or rapidly deploy ransomware across shared network drives.

6. Unencrypted Legacy R-Services (rlogin, rexec, rsh)

What it is: The server exposes outdated Unix remote access services that transmit data in plain text. Furthermore, rlogin is configured to allow root access without requiring a password.

Why it matters: Modern networks mandate encrypted administration (like SSH). R-services offer zero cryptographic protection against network sniffing.

Potential Impact: An insider threat or a compromised device on the same local network segment could silently capture administrative credentials in transit, or simply log in without credentials to seize absolute control of the GMDC host.

7. Operating System End of Life (Ubuntu 8.04)

What it is: The underlying operating system has been unsupported since May 9, 2013.

Why it matters: Canonical no longer provides security patches for this version. Any public exploit developed for the Linux kernel or core packages since 2013 will likely work against this machine out-of-the-box.

Potential Impact: The system is inherently indefensible. Regardless of how well individual applications are secured, the foundation itself is porous, guaranteeing that a determined attacker can bypass perimeter defenses and compromise the GMDC server.